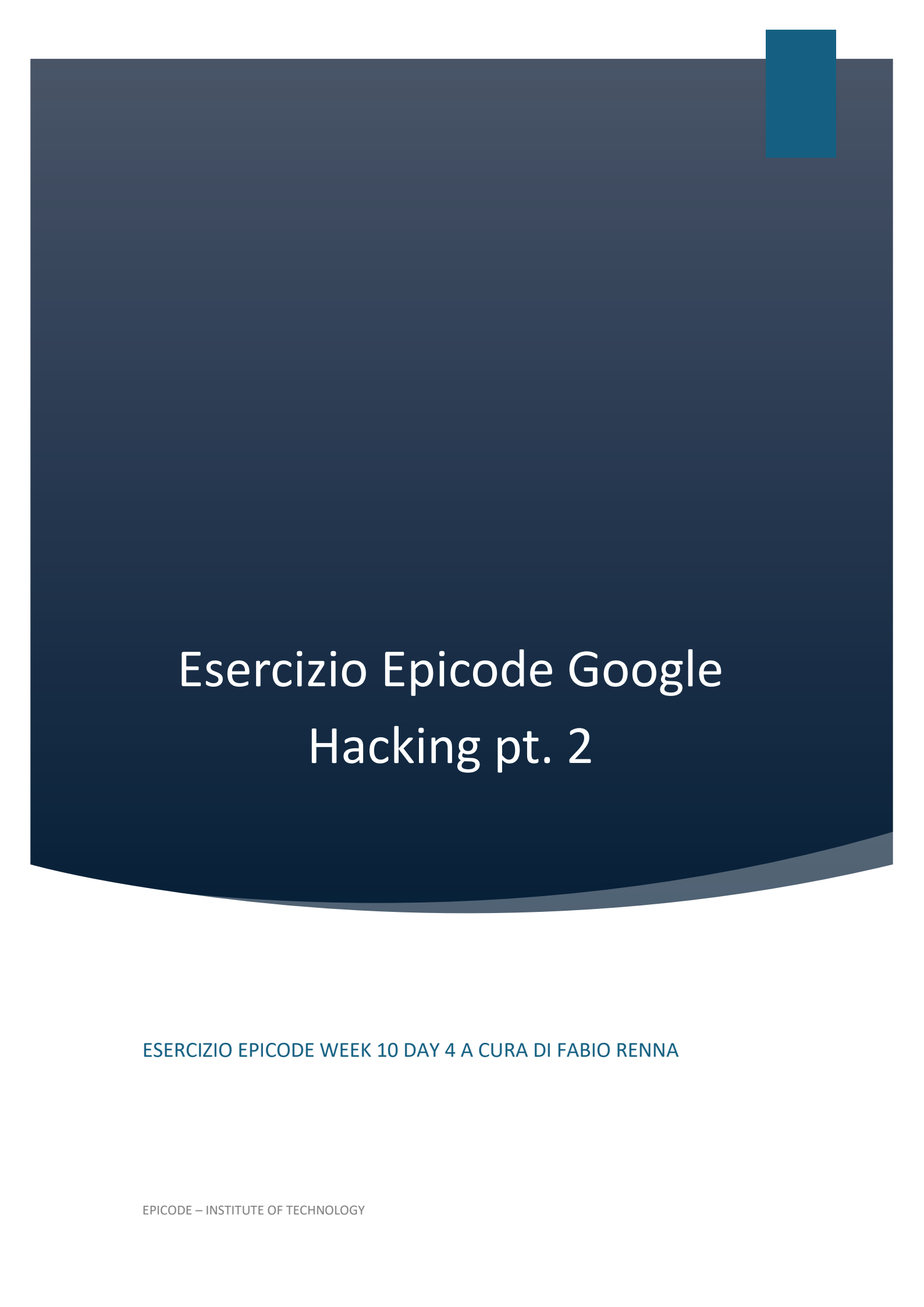




Esercizio Epcode Google Hacking pt. 2

ESERCIZIO EPICODE WEEK 10 DAY 4 A CURA DI FABIO RENNA

Indice

Executive Summary.....	2
Introduzione.....	2
Obiettivo.....	3
Proof of Concept.....	3-8
Conclusione.....	9

Executive Summary

L'attività svolta ha avuto come obiettivo l'utilizzo di diversi strumenti di host scanning ed enumeration per raccogliere informazioni su una macchina Metasploitable all'interno di una rete locale. Attraverso l'uso combinato di Nmap, Netdiscover e Unicornscan, è stato possibile individuare l'host, identificare il sistema operativo, enumerare le porte aperte e determinare i servizi e le relative versioni in esecuzione.

Le scansioni hanno evidenziato una superficie d'attacco estremamente ampia, con numerosi servizi obsoleti e notoriamente vulnerabili esposti in rete, oltre all'assenza di meccanismi di protezione come firewall, rate limiting o intrusion detection. I risultati ottenuti dimostrano l'efficacia delle tecniche di scanning anche in modalità aggressive o di evasione firewall, e confermano come una configurazione insicura renda possibile ottenere rapidamente informazioni critiche su un sistema target.

Introduzione

In un contesto di penetration testing, la fase di reconnaissance e scanning rappresenta uno dei passaggi più importanti per comprendere la superficie d'attacco di un sistema. L'obiettivo di questo esercizio è applicare alcune delle principali tecniche di host discovery, port scanning e service enumeration utilizzando strumenti comunemente presenti in Kali Linux.

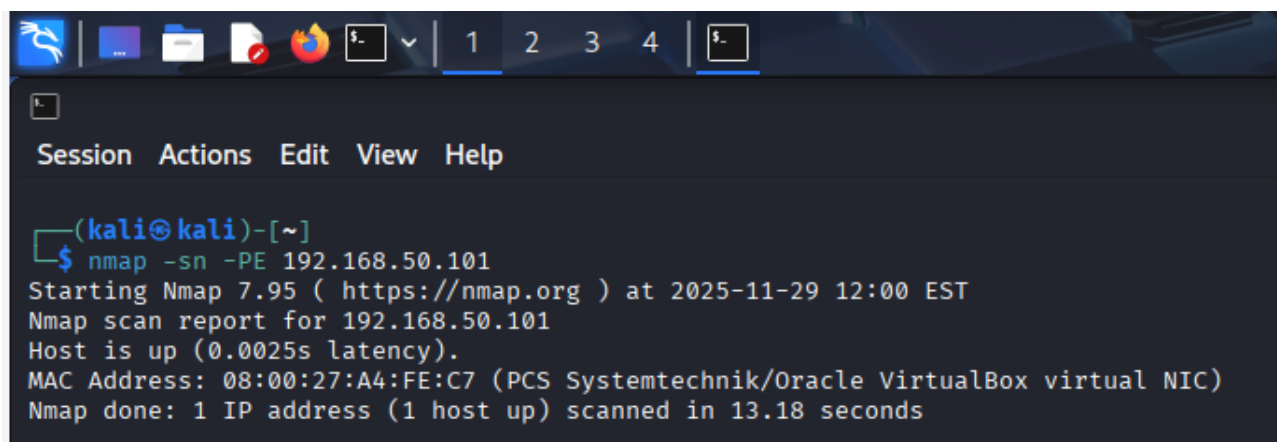
Partendo dall'individuazione dell'host nella rete locale, sono stati eseguiti diversi tipi di scansione, sia standard che avanzate, incluse scansioni stealth, scansioni ad alta velocità e tecniche di evasione firewall. L'ambiente analizzato è una macchina Metasploitable, progettata intenzionalmente per essere vulnerabile e ideale per l'apprendimento delle tecniche di sicurezza offensiva. L'esercizio permette quindi di osservare in modo pratico come strumenti diversi possano fornire informazioni complementari sullo stesso target.

Obiettivo

L'obiettivo principale dell'esercizio è acquisire familiarità con le tecniche di host scanning ed enumeration, utilizzando diversi strumenti disponibili in Kali Linux per raccogliere informazioni su un sistema target. Attraverso l'esecuzione di comandi mirati, l'attività mira a individuare la presenza dell'host nella rete, identificare le porte aperte e analizzare i servizi esposti, comprese le relative versioni e i protocolli utilizzati.

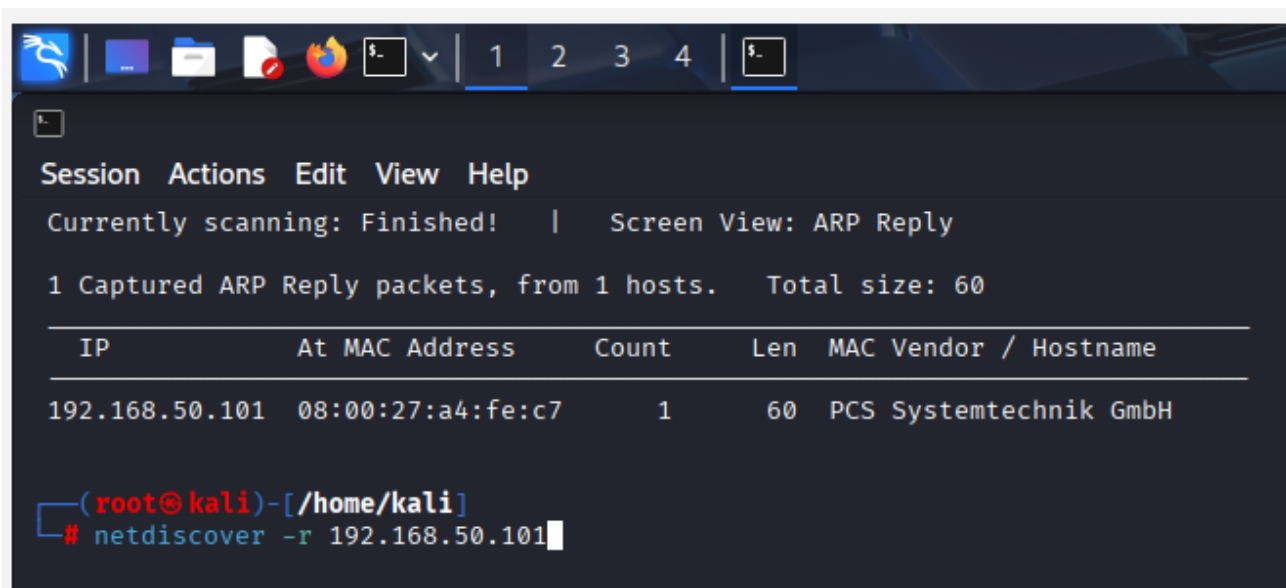
Un ulteriore obiettivo è comprendere come strumenti differenti, come Nmap, Netdiscover e Unicornscan, possano fornire risultati complementari e come tecniche di scansione più aggressive o orientate all'evasione firewall permettano di ottenere informazioni anche in assenza di adeguate difese di rete. Infine, l'esercizio ha lo scopo di sviluppare la capacità di interpretare correttamente gli output prodotti dagli strumenti di scanning e di sintetizzare le informazioni raccolte all'interno di un report tecnico strutturato.

Proof of Concept



```
(kali㉿kali)-[~]  
$ nmap -sn -PE 192.168.50.101  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-29 12:00 EST  
Nmap scan report for 192.168.50.101  
Host is up (0.0025s latency).  
MAC Address: 08:00:27:A4:FE:C7 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)  
Nmap done: 1 IP address (1 host up) scanned in 13.18 seconds
```

Questo comando viene utilizzato per verificare se l'host è attivo in rete senza effettuare una scansione delle porte. Dall'output si osserva che l'indirizzo IP 192.168.50.101 risponde correttamente, confermando la presenza di un host raggiungibile all'interno della rete locale.



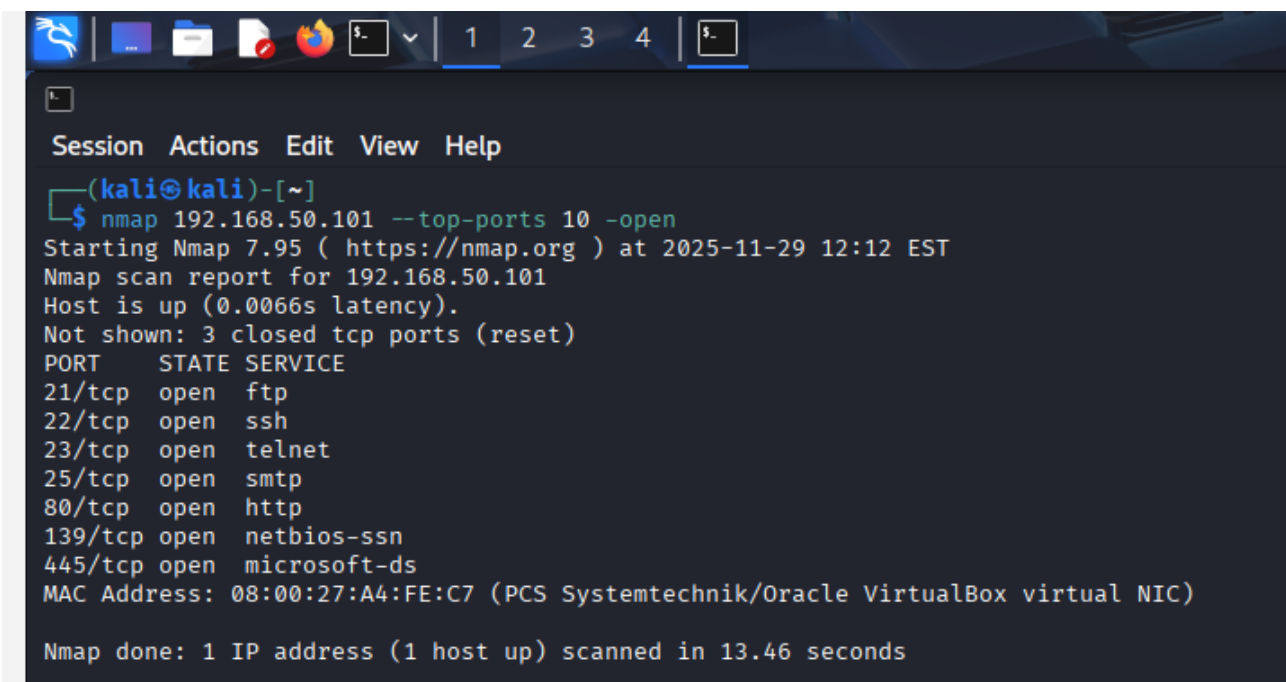
```
Session Actions Edit View Help
Currently scanning: Finished! | Screen View: ARP Reply

1 Captured ARP Reply packets, from 1 hosts. Total size: 60
```

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.50.101	08:00:27:a4:fe:c7	1	60	PCS Systemtechnik GmbH

```
(root@kali)-[/home/kali]
# netdiscover -r 192.168.50.101
```

Attraverso una scansione ARP, questo strumento permette di identificare i dispositivi presenti nella rete locale anche in assenza di risposte ICMP. L'output conferma l'associazione tra l'indirizzo IP e un MAC Address riconducibile a una scheda di rete VirtualBox, indicando che si tratta di una macchina virtuale.



```
(kali@kali)-[~]
$ nmap 192.168.50.101 --top-ports 10 -open
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-29 12:12 EST
Nmap scan report for 192.168.50.101
Host is up (0.0066s latency).
Not shown: 3 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
80/tcp    open  http
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
MAC Address: 08:00:27:A4:FE:C7 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 13.46 seconds
```

Questo comando esegue la scansione delle porte più comunemente utilizzate, mostrando solo quelle effettivamente aperte. Dai risultati emerge che il target espone diversi servizi critici come FTP, SSH, Telnet e HTTP, suggerendo una superficie d'attacco già significativa.

```
(kali@kali)-[~]
$ sudo nmap -mT -Iv 192.168.50.101:a -r 3000 -R 3 66 us -mU -Iv 192.168.50.101:a -r 3000 -R 3
[sudo] password for kali:
adding 192.168.50.101/32 mode 'TCPscan' ports 'a' pps 3000
using interface(s) eth0
scanning 1.00e+00 total hosts with 1.97e+05 total packets, should take a little longer than 1 Minutes, 12 Seconds
TCP open 192.168.50.101:445 ttl 64
TCP open 192.168.50.101:513 ttl 64
TCP open 192.168.50.101:80 ttl 64
TCP open 192.168.50.101:5900 ttl 64
TCP open 192.168.50.101:22 ttl 64
TCP open 192.168.50.101:53 ttl 64
TCP open 192.168.50.101:111 ttl 64
TCP open 192.168.50.101:6697 ttl 64
TCP open 192.168.50.101:2121 ttl 64
TCP open 192.168.50.101:43465 ttl 64
TCP open 192.168.50.101:8787 ttl 64
TCP open 192.168.50.101:3632 ttl 64
TCP open 192.168.50.101:6667 ttl 64
TCP open 192.168.50.101:57292 ttl 64
TCP open 192.168.50.101:2049 ttl 64
TCP open 192.168.50.101:512 ttl 64
TCP open 192.168.50.101:139 ttl 64
TCP open 192.168.50.101:8009 ttl 64
TCP open 192.168.50.101:8180 ttl 64
TCP open 192.168.50.101:36688 ttl 64
TCP open 192.168.50.101:25 ttl 64
TCP open 192.168.50.101:43120 ttl 64
TCP open 192.168.50.101:5432 ttl 64
TCP open 192.168.50.101:514 ttl 64
TCP open 192.168.50.101:6000 ttl 64
TCP open 192.168.50.101:1099 ttl 64
TCP open 192.168.50.101:21 ttl 64
TCP open 192.168.50.101:3306 ttl 64
TCP open 192.168.50.101:23 ttl 64
TCP open 192.168.50.101:1524 ttl 64
sender statistics 1800.8 pps with 196608 packets sent total
```

```

TCP open 192.168.50.101:5432  ttl 64
TCP open 192.168.50.101:514  ttl 64
TCP open 192.168.50.101:6000  ttl 64
TCP open 192.168.50.101:1099  ttl 64
TCP open 192.168.50.101:21  ttl 64
TCP open 192.168.50.101:3306  ttl 64
TCP open 192.168.50.101:23  ttl 64
TCP open 192.168.50.101:1524  ttl 64
sender statistics 1800.8 pps with 196608 packets sent total
listener statistics 196573 packets recieved 0 packets dropped and 0 interface drops
TCP open          ftp[ 21]          from 192.168.50.101  ttl 64
TCP open          ssh[ 22]          from 192.168.50.101  ttl 64
TCP open          telnet[ 23]        from 192.168.50.101  ttl 64
TCP open          smtp[ 25]          from 192.168.50.101  ttl 64
TCP open          domain[ 53]        from 192.168.50.101  ttl 64
TCP open          http[ 80]          from 192.168.50.101  ttl 64
TCP open          sunrpc[ 111]        from 192.168.50.101  ttl 64
TCP open          netbios-ssn[ 139]   from 192.168.50.101  ttl 64
TCP open          microsoft-ds[ 445]  from 192.168.50.101  ttl 64
TCP open          exec[ 512]         from 192.168.50.101  ttl 64
TCP open          login[ 513]        from 192.168.50.101  ttl 64
TCP open          shell[ 514]        from 192.168.50.101  ttl 64
TCP open          rmiregistry[ 1099]  from 192.168.50.101  ttl 64
TCP open          ingreslock[ 1524]  from 192.168.50.101  ttl 64
TCP open          shilp[ 2049]       from 192.168.50.101  ttl 64
TCP open          scientia-ssdb[ 2121] from 192.168.50.101  ttl 64
TCP open          mysql[ 3306]       from 192.168.50.101  ttl 64
TCP open          distcc[ 3632]      from 192.168.50.101  ttl 64
TCP open          postgresql[ 5432]  from 192.168.50.101  ttl 64
TCP open          winvnc[ 5900]      from 192.168.50.101  ttl 64
TCP open          x11[ 6000]         from 192.168.50.101  ttl 64
TCP open          irc[ 6667]         from 192.168.50.101  ttl 64
TCP open          unknown[ 6697]     from 192.168.50.101  ttl 64
TCP open          unknown[ 8009]     from 192.168.50.101  ttl 64
TCP open          unknown[ 8180]     from 192.168.50.101  ttl 64
TCP open          msgsrvr[ 8787]     from 192.168.50.101  ttl 64
TCP open          unknown[36688]     from 192.168.50.101  ttl 64
TCP open          unknown[43120]     from 192.168.50.101  ttl 64
TCP open          unknown[43465]     from 192.168.50.101  ttl 64

```

In questo comando viene utilizzato *Unicornscan* per eseguire una scansione completa delle porte TCP e UDP del target ad alta velocità. La scansione, ripetuta più volte con un elevato rate di pacchetti al secondo, consente di individuare rapidamente numerose porte aperte e dimostra come il sistema risponda regolarmente, evidenziando l'assenza di firewall efficaci, sistemi di rate limiting o meccanismi di intrusion detection.

```

(kali@kali)-[~]
$ nmap -sS -sV -T4 192.168.50.101
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-08 16:20 EST
Nmap scan report for 192.168.50.101
Host is up (0.0022s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rshd
513/tcp   open  login?
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:A4:FE:C7 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 66.19 seconds

```

Questa scansione combina l'individuazione stealth delle porte con il rilevamento delle versioni dei servizi. L'output mostra chiaramente software obsoleto e vulnerabile, come vsFTPD 2.3.4, Apache 2.2.8 e Samba 3.x, tipici della macchina Metasploitable.

```

(kali@kali)-[~]
$ nc -nv 192.168.50.101 22
(UNKNOWN) [192.168.50.101] 22 (ssh) open
SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1

```

La scansione mirata della porta 22 consente di verificare rapidamente lo stato del servizio SSH. Il risultato conferma che il servizio è attivo e utilizza una versione datata di OpenSSH, potenzialmente soggetta a vulnerabilità note.

```

(kali@kali)-[~]
$ sudo hping3 --scan known 192.168.50.101
Scanning 192.168.50.101 (192.168.50.101), port known
266 ports to scan, use -V to see all the replies
|port| serv name | flags | ttl | id | win | len |
|-----|-----|-----|-----|-----|-----|-----|
All replies received. Done.
Not responding ports: (21 ftp) (22 ssh) (23 telnet) (25 smtp) (53 domain) (80 http) (111 sunrpc) (139 netbios-ssn) (445 microsoft-d) (512 exec) (513 login) (514 shell) (1099 rmiregistry)
(1524 ingreslock) (2049 nfs) (2121 iprop) (3306 mysql) (3632 distcc) (5432 postgresql) (6000 x11) (6667 ircd) (6697 ircs-u)

```

Questo strumento effettua una scansione delle porte utilizzando pacchetti TCP personalizzati, offrendo un metodo alternativo rispetto a Nmap. I risultati confermano la presenza di numerose porte aperte già individuate in precedenza, rafforzando l'affidabilità delle informazioni raccolte.


```

(kali㉿kali)-[~]
└─$ nmap -f --mtu=512 192.168.50.101
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-08 16:28 EST
Nmap scan report for 192.168.50.101
Host is up (0.00050s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:A4:FE:C7 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 13.41 seconds

```

La scansione con pacchetti frammentati viene utilizzata per tentare l'elusione di firewall o sistemi di rilevamento. Nonostante l'uso di questa tecnica, l'host risponde regolarmente e rivela numerose porte aperte, indicando l'assenza di contromisure di rete efficaci.

Conclusione

L'analisi complessiva della macchina Metasploitable ha messo in evidenza un sistema estremamente esposto e privo di adeguate misure di sicurezza. Le attività di host discovery hanno confermato la presenza della macchina all'interno della rete locale e la sua natura di macchina virtuale. Le successive scansioni delle porte hanno rivelato un numero elevato di servizi attivi, tra cui FTP, SSH, Telnet, SMTP, HTTP, SMB, RPC, NFS, MySQL, PostgreSQL, VNC, IRC e altri servizi legacy, molti dei quali associati a versioni obsolete e note per essere vulnerabili.

Le scansioni più avanzate hanno inoltre dimostrato che il sistema risponde correttamente anche a tecniche di scanning aggressive e ad alta velocità, incluse scansioni con pacchetti frammentati e

scansioni TCP/UDP complete tramite Unicornscan. Questo comportamento indica l'assenza di firewall efficaci, di meccanismi di rate limiting e di sistemi di intrusion detection, rendendo il target facilmente analizzabile anche con strumenti molto rumorosi.

Nel complesso, l'esercizio evidenzia come una configurazione insicura permetta a un attaccante di raccogliere rapidamente informazioni dettagliate sull'host, sui servizi e sulle tecnologie utilizzate, costituendo una base solida per eventuali fasi successive di exploitation e post-exploitation. L'attività svolta dimostra l'importanza di una corretta configurazione dei servizi di rete e di adeguate misure di difesa per ridurre la visibilità e la superficie d'attacco di un sistema.

Venezia, 27/11/2025

Fabio Renna